

CUADERNO DE PRACTICAS

UD1 — Seguridad y Normativas

ISO 27002:2022 aplicada al laboratorio y analisis de brecha real

MF0490_3 | IFCT0109 Seguridad Informatica

Modulo	MF0490_3 — Gestion de Servicios en el Sistema Informatico
Unidad	UD1 — Gestion de la Seguridad y Normativas (10 horas)
Entorno	DC01 · ubuntu-moderna · Security Onion · Wazuh · OPNsense · Proxmox VE
Acceso lab	https://juanprofesor.com (Apache Guacamole)

Num.	Practica	Enfoque	Nivel	Horas
N-01	Mapeo de ISO 27002:2022 a la infraestructura del laboratorio	Auditoria aplicada	Intermedia	3 h
N-02	Analisis de brecha real: SolarWinds Sunburst (2020)	Caso real + ISO 27002	Intermedia	3 h

PRACTICA N-01

Mapeo de Controles ISO 27002:2022 al Laboratorio IFCT0109

UD1 — Gestión de la Seguridad y Normativas · 3 horas · Intermedia

Objetivo

Aplicar los 93 controles de ISO/IEC 27002:2022 sobre la infraestructura real del laboratorio IFCT0109, evaluando el grado de cumplimiento actual de cada control (Cumple / Parcial / No Cumple / N/A), identificando los gaps mas significativos y proponiendo medidas correctoras priorizadas.

Infraestructura del laboratorio

DC01 (10.1.99.60) · ubuntu-moderna (10.1.99.50) · Security Onion (192.168.0.252) · Wazuh (192.168.99.20) · OPNsense (VM-100) · Proxmox VE (servidor jaf) · Guacamole (juanprofesor.com)

PASO 1 — Inventario y clasificacion de activos del laboratorio

Antes de evaluar controles, es imprescindible tener un inventario de activos. Rellena la siguiente tabla con los activos del laboratorio. Algunos ya estan completados como referencia; añade o ajusta segun lo que observes en tu entorno.

Activo	Tipo	Clasificacion	Propietario	Ubicacion / Acceso
DC01 (VM-108)	Sistema	Confidencial	Administrador	Proxmox / 10.1.99.60 / RDP+Guacamole
ubuntu-moderna (VM-107)	Sistema	Confidencial	Administrador	Proxmox / 10.1.99.50 / SSH+Guacamole
Security Onion (VM-101)	Sistema	Restringido	Administrador	Proxmox / 192.168.0.252 / Web HTTPS
Wazuh (VM-200)	Sistema	Restringido	Administrador	Proxmox / 192.168.99.20 / Web HTTPS
OPNsense (VM-100)	Red	Restringido	Administrador	Proxmox / 192.168.0.1 / Web HTTPS
Proxmox VE (jaf)	Plataforma	Restringido	Administrador	Fisico CPD / Web HTTPS 8006
Metasploitable2 (VM-106)	Sistema	Publico	Administrador	Proxmox / 10.1.99.109 / Red aislada
Logs Elasticsearch	Datos	Confidencial	Administrador	Security Onion / indices ES
Configuracion SaltStack	Datos	Restringido	Administrador	Security Onion / /opt/so/saltstack
_____ (VM-____)	_____	_____	_____	_____
_____ (VM-____)	_____	_____	_____	_____

Pregunta 1: La norma ISO 27002 exige en el control 5.9 que cada activo tenga un propietario claramente asignado. ¿Qué problema practico puede surgir en un entorno de laboratorio donde todos los activos tienen el mismo propietario (Administrador)? ¿Como lo resolverías en un entorno real?

PASO 2 — Evaluación de controles organizativos (clausula 5)

Evalúa el grado de cumplimiento de los siguientes controles de la cláusula 5 en el laboratorio. Marca el estado y justifica brevemente tu valoración en la columna 'Evidencia / Razonamiento'.

Criterios de evaluacion

CUMPLE: el control esta implementado y documentado. PARCIAL: implementado, pero sin documentar, o implementado solo para algunos activos. NO CUMPLE: el control no existe. N/A: no aplica al entorno.

Control	Nombre	Estado	Evidencia / Razonamiento
5.1	Políticas de seguridad de la informacion	PARCIAL	No existe politica formal escrita. Las reglas son implícitas y conocidas por el profesor.
5.2	Roles y responsabilidades de seguridad	PARCIAL	Un único administrador gestiona todo. No hay segregación de roles documentada.
5.3	Segregación de funciones	NO CUMPLE	El mismo usuario administra, opera y audita. En producción esto sería una no conformidad grave.
5.7	Inteligencia de amenazas	CUMPLE	Security Onion + Wazuh generan alertas correlacionadas con MITRE ATT&CK.
5.9	Inventario de activos de información	PARCIAL	
5.12	Clasificación de la información	NO CUMPLE	
5.15	Control de acceso	PARCIAL	
5.16	Gestión de identidades	PARCIAL	Active Directory en DC01 gestiona identidades del dominio lab.local.
5.24	Planificación de la gestión de incidentes	CUMPLE	TheHive + Cortex + Wazuh configurados para recibir y gestionar alertas.
5.30	Preparación TIC para la continuidad del negocio	PARCIAL	
5.34	Privacidad y protección de datos personales (PII)	NO CUMPLE	
5.35	Revisión independiente de la SI	NO CUMPLE	

Pregunta 2: ¿Por qué el control 5.3 (Segregación de funciones) aparece como NO CUMPLE en el laboratorio pero esto es aceptable en este contexto? ¿En qué tipo de organización real sería inaceptable y que consecuencias podría tener?

PASO 3 — Evaluación de controles tecnológicos clave (clausula 8)

La cláusula 8 es la más extensa (34 controles) y la más directamente aplicable a la infraestructura del laboratorio. Evalúa los siguientes controles de alto impacto:

Control	Nombre	Estado	Evidencia / Justificacion
8.2	Derechos de acceso privilegiado	PARCIAL	Solo existe la cuenta Administrador en DC01. No hay cuentas de servicio separadas.
8.5	Autenticación segura	PARCIAL	Autenticación por password. No se usa MFA en el lab. En producción sería insuficiente.
8.7	Protección contra malware	CUMPLE	Wazuh HIDS detecta indicadores de malware. Windows Defender activo en DC01.
8.8	Gestión de vulnerabilidades técnicas	PARCIAL	
8.9	Gestión de la configuración	CUMPLE	SaltStack gestiona la configuracion de Security Onion de forma centralizada.
8.12	Prevención de fuga de datos (DLP)	NO CUMPLE	
8.15	Registro de eventos (logging)	CUMPLE	Elasticsearch centraliza logs. Sysmon v15 en DC01. journalctl + auditd en ubuntu-moderna.
8.16	Monitorización de actividades	CUMPLE	Security Onion + Suricata + Zeek monitorizan trafico. Elastic Agents reportan metricas.
8.20	Seguridad en redes	CUMPLE	OPNsense como firewall perimetral. Segmentacion en vmbr1 (LAN) y vmbr2 (DMZ).
8.22	Segregacion de redes	CUMPLE	Tres segmentos: 192.168.0.0/24 (WAN), 192.168.99.0/24 (LAN), 10.1.99.0/24 (DMZ).
8.24	Uso de criptografía	PARCIAL	
8.25	Ciclo de vida de desarrollo seguro	N/A	No hay desarrollo de software en el lab.
8.29	Pruebas de seguridad en desarrollo	N/A	No aplica en este contexto.
8.34	Protección de sistemas durante auditoria	PARCIAL	

Controles marcados como PARCIAL

Para los controles con evidencia vacía, rellena la justificacion basandote en tu conocimiento del laboratorio. Si no puedes verificar un control directamente, indica que prueba necesitarías hacer para comprobarlo (por ejemplo: 'Necesitaría revisar si los logs de Elasticsearch tienen politica de retención configurada').

Pregunta 3: El control 8.8 (Gestión de vulnerabilidades técnicas) aparece como PARCIAL. ¿Qué herramienta del laboratorio podrías usar para obtener un inventario de CVEs conocidos en Metasploitable2? Describe brevemente el proceso.

PASO 4 — Resumen ejecutivo de gaps y plan de mejora

Con los resultados de los pasos anteriores, elabora un resumen de los 5 gaps más significativos y una propuesta de mejora para cada uno. Prioriza por impacto potencial en la seguridad del laboratorio.

P	Control ID	Impacto	Gap identificado	Accion correctora propuesta
1				
2				

MF0490_3 — UD1: Seguridad y Normativas · Practicas N-01 / N-02				IFCT0109 · juanprofesor.com
3				
4				
5				

Pregunta 4: ¿Cuál es el gap que consideras más crítico y por qué? Relaciona tu respuesta con uno de los principios de la norma ISO 27001 (confidencialidad, integridad o disponibilidad).

ENTREGABLE

- Tabla de inventario de activos completada con todos los campos.
- Tabla de controles de la cláusula 5 con los campos de evidencia rellenados (incluyendo los que estaban vacíos).
- Tabla de controles de la cláusula 8 con todos los campos completados.
- Tabla de resumen de gaps con los 5 más significativos y sus acciones correctoras.
- Respuestas razonadas a las 4 preguntas.

PRACTICA N-02

Analisis de Brecha Real: SolarWinds Sunburst (2020)

Mapeo de la Cadena de Ataque a ISO 27002:2022

UD1 — Gestión de la Seguridad y Normativas · 3 horas · Intermedia

Objetivo

Analizar la brecha de seguridad de SolarWinds (2020), uno de los incidentes más significativos de la historia de la ciberseguridad, descomponiendo la cadena de ataque fase a fase y mapeando cada fase a los controles de ISO/IEC 27002:2022 que podrían haberla detectado, dificultado o prevenido. Finalmente, aplicar las lecciones aprendidas al contexto del laboratorio IFCT0109.

SolarWinds Sunburst — Resumen ejecutivo

Entre octubre de 2019 y diciembre de 2020, actores de amenaza estatales (atribuidos a SVR ruso, grupo Cozy Bear / APT29) comprometieron la cadena de suministro de SolarWinds, empresa proveedora de software de monitorización de red (Orion). Los atacantes insertaron un backdoor (SUNBURST) en las actualizaciones legítimas del software, que se distribuyeron a aproximadamente 18.000 organizaciones, incluyendo agencias gubernamentales de EE.UU. (Treasury, Commerce, State, DHS, NSA) y empresas Fortune 500. La brecha no fue detectada durante más de 14 meses.

Fuentes para la investigación

CISA Alert AA20-352A (disponible en [cisa.gov](https://www.cisa.gov)) · Informe de FireEye/Mandiant sobre SUNBURST · Comunicado del Senado de EE.UU. sobre el incidente SolarWinds · CVE-2020-10148 (vulnerabilidad API SolarWinds Orion)

PASO 1 — Descomposición de la cadena de ataque

El ataque SolarWinds siguió una cadena de ataque sofisticada en múltiples fases. Lee el resumen de cada fase y completa los campos vacíos basándote en tu investigación y en los contenidos de la UD1.

Fase	Nombre	Descripción del ataque	MITRE ATT&CK (Táctica / Técnica)
1	Compromiso inicial de la cadena de suministro	Los atacantes accedieron al entorno de desarrollo de SolarWinds e inyectaron código malicioso (SUNBURST) en el proceso de compilación del software Orion antes de que se firmara digitalmente.	TA0001 Initial Access / T1195.002 Compromise Software Supply Chain
2	Instalación del backdoor SUNBURST	La actualización troyanizada (Orion 2019.4 - 2020.2.1) se distribuyó a ~18.000 clientes como una actualización legítima firmada digitalmente. SUNBURST permanecía dormido 12-14 días antes de activarse.	TA0002 Execution / T1072 Software Deployment Tools
3	Comunicación con infraestructura C2	SUNBURST usaba el protocolo DNS para comunicarse con el dominio avsvmcloud[.]com, camuflando el tráfico como tráfico DNS legítimo de Orion. Las consultas codificaban datos del entorno víctima.	TA0011 Command and Control / T1071.004 Application Layer Protocol: DNS
4	Movimiento lateral y escalada de privilegios	Una vez activo, los atacantes desplegaban TEARDROP (un segundo backdoor) en objetivos de alto valor. Usaban credenciales robadas y tokens SAML falsificados	

MF0490_3 — UD1: Seguridad y Normativas · Practicas N-01 / N-02			IFCT0109 · juanprofesor.com
		para moverse entre entornos on-premise y cloud.	
5	Exfiltración de datos	Los atacantes accedieron a correos electrónicos de alto nivel, documentos clasificados y código fuente en múltiples agencias. La exfiltración se realizaba de forma lenta y discreta para evitar detección por volumetría.	
6	Persistencia a largo plazo	Los atacantes mantuvieron acceso durante más de 14 meses. Eliminaban logs de sus actividades y usaban técnicas de 'living off the land' (herramientas legítimas del sistema) para no levantar alarmas.	

Pregunta 1: Completa las tácticas y técnicas MITRE ATT&CK de las fases 4, 5 y 6. ¿Qué recurso usarías para buscar esta información? (Pista: attack.mitre.org)

PASO 2 — Mapeo de fases del ataque a controles ISO 27002:2022

Para cada fase del ataque, identifica los controles de ISO 27002:2022 que, de haber estado correctamente implementados, podrían haber prevenido, dificultado o detectado el ataque. Algunos campos ya están cumplimentados como guía.

Fase	Nombre de la fase	Controles ISO 27002 (Prevenir)	Controles ISO 27002 (Detectar)	Razonamiento
1	Compromiso cadena suministro	5.19 SI en relaciones con proveedores 5.20 SI en acuerdos con proveedores 5.21 SI en cadena de suministro TIC	8.8 Gestión de vulnerabilidades 8.29 Pruebas de seguridad	Si SolarWinds hubiera tenido controles 5.19-5.21 robustos y sus clientes hubieran exigido garantías de seguridad en la cadena de suministro (SBOM, firma de código verificable), el riesgo habría sido menor.
2	Instalación del backdoor	8.25 Ciclo de vida de desarrollo seguro 8.28 Codificación segura	8.7 Protección contra malware 8.16 Monitorización de actividades	Un proceso de desarrollo seguro (DevSecOps) con análisis de código estático (SAST) podría haber detectado el código malicioso antes de la firma y distribución.
3	Comunicación C2 vía DNS			
4	Movimiento lateral y escalada			
5	Exfiltración de datos			
6	Persistencia y borrado de logs			

Pregunta 2: Para la fase 3 (Comunicación C2 vía DNS), ¿qué controles de la cláusula 8 de ISO 27002 habrían sido más útiles para detectar el tráfico DNS anómalo? ¿Hay alguna herramienta del laboratorio IFCT0109 que ya implementé alguno de esos controles?

PASO 3 — Análisis de los fallos de control principales

El informe del Comité del Senado de EE.UU. sobre el incidente SolarWinds identificó varios fallos de control críticos. Relaciona cada fallo con el control ISO 27002:2022 que no estaba correctamente implementado y propone como debería haberse implementado.

Fallo de control identificado	Control ISO 27002	Como debería implementarse
SolarWinds usaba la contraseña 'solarwinds123' para su servidor de actualizaciones (expuesta en GitHub).	5.17 Información de autenticación	Política de contraseñas robusta, escaneo de secretos en repositorios (ej: git-secrets, Trufflehog), MFA en sistemas críticos.
Las agencias víctimas no revisaban la integridad del software descargado antes de desplegarlo.	5.21 SI en cadena de suministro TIC	
El tráfico DNS anómalo no fue detectado durante 14 meses en entornos con presupuesto de seguridad millonario.		Sistemas SIEM con reglas de detección de DNS tunneling y DGA (Domain Generation Algorithms). Baselines de tráfico DNS normal.
Los logs de actividad de los atacantes fueron borrados sin que nadie lo detectara.		
Los tokens SAML falsificados no levantaron alertas en los sistemas de IAM.	5.16 Gestión de identidades 5.18 Derechos de acceso	
No existía un proceso formal de gestión de incidentes que conectara los indicadores aislados detectados.		

Pregunta 3: El borrado de logs por parte de los atacantes (fila 4 de la tabla anterior) es especialmente crítico. ¿Qué controles de ISO 27002 aplican? ¿Como podría haberse evitado en el laboratorio IFCT0109 usando Security Onion y Elasticsearch?

PASO 4 — Lecciones aprendidas: aplicación al laboratorio IFCT0109

El verdadero valor de analizar una brecha real es extraer lecciones aplicables a tu propio entorno. Rellena la siguiente tabla trasladando las lecciones de SolarWinds al contexto del laboratorio.

Lección aprendida del caso SolarWinds	¿Aplica al lab IFCT0109?	Medida concreta en el laboratorio
Verificar la integridad del software antes de desplegar (checksums, firmas).	SI — Proxmox descarga ISOs de internet. Security Onion se actualiza vía so-update.	Verificar SHA256 de todas las ISOs descargadas. Revisar los logs de so-update antes de aplicar actualizaciones.
Monitorizar tráfico DNS para detectar C2 y exfiltración.		

MF0490_3 — UD1: Seguridad y Normativas · Practicas N-01 / N-02		IFCT0109 · juanprofesor.com
Los logs deben almacenarse en un sistema separado y protegido de escritura.	SI — Los logs de Elasticsearch en Security Onion son el unico repositorio centralizado.	
Implementar el principio de mínimo privilegio en todos los sistemas.		
Establecer baselines de comportamiento normal para detectar anomalías.		
Disponer de un plan de respuesta a incidentes documentado y probado.	SI — TheHive y Cortex están disponibles pero el playbook no esta documentado.	

Pregunta 4: Considerando las 6 lecciones de la tabla anterior, ¿cuál es la que el laboratorio IFCT0109 tiene PEOR cubierta actualmente? Justifica tu respuesta y propone una accion concreta y realizable para mejorarla.

REFLEXION FINAL — El factor humano

Una reflexion importante

El ataque SolarWinds fue posible en parte porque los controles tecnicos existentes no eran suficientes sin los controles organizativos adecuados. Kevin Mandia (CEO de Mandiant, empresa que descubrio el ataque) afirmo que 'se trató de un ataque de un estado-nación que utilizo técnicas que la mayoría de las empresas no tenían en su modelo de amenazas'. Esto ilustra perfectamente porque ISO 27002 combina controles técnicos (clausula 8) con controles organizativos (clausula 5) y de personas (clausula 6).

Pregunta 5: ¿Que controles de la cláusula 6 (Personas) de ISO 27002:2022 podrían haber contribuido a una detección más rápida del ataque SolarWinds? Menciona al menos dos y explica cómo.

ENTREGABLE

- Tabla de la cadena de ataque completada con las tácticas y técnicas MITRE de las fases 4, 5 y 6.
- Tabla de mapeo fases-controles ISO 27002 con todas las filas completadas (fases 3 a 6).
- Tabla de fallos de control con los campos vacios rellenos (control ISO y como implementarlo).
- Tabla de lecciones aprendidas completada con las filas de aplicacion al laboratorio.
- Respuestas razonadas a las 5 preguntas.
- OPCIONAL (+1 punto): Busca en el NVD (nvd.nist.gov) la CVE-2020-10148 y elabora un parrafo adicional sobre como el control 8.8 (Gestion de vulnerabilidades) deberia haberse aplicado para mitigarla.